

Studiengänge: BA Cyber Security Management, BA Cyber Security Management dual,
BA W Cyber Security Management Teilzeit

Realistische Übungsklausur - Variante B

BCSM 402 - Business Continuity Management

Sommersemester 2026 | Prof. Dr. Gael Pentang

Name	
Matrikel-Nr.	
Hiermit erkläre ich, dass ich prüfungsfähig bin.	

- Erlaubte Hilfsmittel: Stifte, Textmarker, Taschenrechner.
- Die Unterlage umfasst insgesamt 14 Seiten (einschließlich Deckblatt) mit 8 Aufgaben: 1 Single-Choice-Aufgabe, 5 Freitextaufgaben und einer Case Study mit 2 Aufgaben.
- Zum Bestehen der Klausur sind insgesamt mindestens 61 Punkte erforderlich.
- Wenn Ihnen der vorhandene Platz nicht ausreicht, können Sie die Rückseiten benutzen. Zusätzliche Blätter sind mit Name und Matrikel-Nr. zu beschriften.
- Schreiben Sie nicht mit Bleistift. Markieren Sie bei Single-Choice-Fragen genau eine Antwortmöglichkeit.

	erreichte Punktzahl
Prüfungsabschnitt 1: 20 Single-Choice-Fragen	40
Aufgabe 1	
Prüfungsabschnitt 2: Freitextaufgaben	40
Aufgabe 2	
Aufgabe 3	
Aufgabe 4	
Aufgabe 5	
Aufgabe 6	
Prüfungsabschnitt 3: Case Study	40
Aufgabe 7	
Aufgabe 8	
Summe	120

Hinweis: Diese Übungsklausur wurde anhand des Original-Deckblatts, der Probeklausur, der Themen-Eingrenzung, der Vorlesungsfolien und der Übungen erstellt. Sie ist keine offizielle Klausur.

Prüfungsabschnitt 1

Aufgabe 1 - Single-Choice-Fragen (20 x 2 = 40 Punkte)

Bitte markieren Sie genau eine Antwortmöglichkeit. Nur jeweils eine Antwort ist richtig. Werden mehrere Antworten markiert, wird die Frage mit 0 Punkten bewertet.

1. Welche Definition beschreibt einen Stakeholder im BCM am besten?
 - a. Eine Person, Gruppe oder Organisation, die die Organisation beeinflusst oder von ihren Aktivitäten, Entscheidungen oder Ergebnissen beeinflusst wird
 - b. Nur ein externer Kunde mit laufendem Vertrag
 - c. Ausschließlich eine Aufsichtsbehörde
 - d. Nur Mitarbeitende im BCMS-Scope
 - e. Keine von a. bis d.
2. Welche Aussage zu den BCI Good Practice Guidelines trifft zu?
 - a. Sie sind eine internationale Muss-Norm zur Organisationszertifizierung.
 - b. Sie sind ein praxisorientierter Leitfaden des Berufsverbands BCI und unterstützen BCM-Praktiker.
 - c. Sie ersetzen die ISO 22301 vollständig.
 - d. Sie gelten nur für deutsche Behörden.
 - e. Keine von a. bis d.
3. Was kennzeichnet das Standard-BCMS nach BSI 200-4?
 - a. Vereinfachte Methodik ohne Analysen
 - b. Vollständiger PDCA-Zyklus, vollständige Methodik und grundsätzlich ISO-22301-Zertifizierungsfähigkeit
 - c. Nur Alarmierung und Sofortmaßnahmen
 - d. Ausschluss aller Supportprozesse
 - e. Alles von a. bis d.
4. Welche Aspekte sind bei der Definition des BCMS-Anwendungsbereichs zu berücksichtigen?
 - a. Interne und externe Aspekte, interessierte Parteien sowie rechtliche und behördliche Anforderungen
 - b. Nur die aktuelle Aufbauorganisation
 - c. Nur die IT-Systeme
 - d. Nur die Jahresplanung des Controllings
 - e. Keine von a. bis d.

5. Welche Aussage zur BCM-Leitlinie ist richtig?
 - a. Sie muss durch das Top-Management genehmigt werden.
 - b. Sie darf nicht dokumentiert werden.
 - c. Sie ist nur für den Krisenstab relevant.
 - d. Sie ersetzt BIA und Risikoanalyse.
 - e. Alles von a. bis d.
6. Wie sind Risiken und Chancen des BCMS zu behandeln?
 - a. Sie werden einmalig erfasst und danach nicht mehr betrachtet.
 - b. Maßnahmen werden geplant, in Prozesse integriert und auf Wirksamkeit bewertet.
 - c. Nur externe Risiken sind relevant.
 - d. Chancen dürfen nicht in BCMS-Ziele einfließen.
 - e. Keine von a. bis d.
7. Welche Aussage zu strategischen und taktisch-operativen BCM-Zielen trifft zu?
 - a. Strategische Ziele sind generell und langfristig; taktisch-operative Ziele sind konkret, messbar und häufig aus BIA/Risikobewertung abgeleitet.
 - b. Strategische Ziele dürfen kein Datum enthalten.
 - c. Operative Ziele werden nicht dokumentiert.
 - d. Beide Zielarten sind identisch.
 - e. Keine von a. bis d.
8. Welche Gruppe nennt ausschließlich Ressourcen eines BCMS?
 - a. Mitarbeitende, Budget, Technologie, Gebäude, dokumentierte Informationen
 - b. Nur Server und Netzwerke
 - c. Kunden, Wettbewerber und Presse
 - d. RTO, RPO, MTPD und MBCO
 - e. Keine von a. bis d.

9. Welchem Zweck dient der BIA-Vorfilter?
- a. Trennung potenziell zeitkritischer von nicht zeitkritischen Prozessen vor der Detailanalyse
 - b. Ersetzung der gesamten BIA
 - c. Festlegung von Auditfeststellungen
 - d. Ermittlung der Ursache eines Cyberangriffs
 - e. Keine von a. bis d.
10. Welche Reihenfolge wird in der Praxis häufig gewählt?
- a. Erst Risikoanalyse, dann BIA, weil Ursachen wichtiger sind
 - b. Erst BIA, dann Risikoanalyse, weil die BIA Schutzbedarfe und Kritikalität als Input liefert
 - c. Beide Verfahren dürfen nie kombiniert werden
 - d. Nur eine BIA ist erforderlich
 - e. Keine von a. bis d.
11. Welche Schadenskategorie gehört zur BIA?
- a. Auswirkungen auf persönliche Sicherheit
 - b. Auswirkungen auf Aufgaben und Leistungen
 - c. Verstöße gegen Gesetze, Vorschriften oder Verträge
 - d. Finanzielle und Image-Auswirkungen
 - e. Alle von a. bis d.
12. Wie wird ein Risiko in einer Risikomatrix typischerweise priorisiert?
- a. Nur nach der Eintrittswahrscheinlichkeit
 - b. Nur nach der Schadenshöhe
 - c. Durch die Kombination aus Eintrittswahrscheinlichkeit und Schadenpotenzial
 - d. Nach der Anzahl vorhandener Dokumente
 - e. Keine von a. bis d.

13. Welche Kriterien sollen bei der Auswahl einer BC-Lösung ausbalanciert werden?
- a. Wirkung, Zeit, Ressourcen sowie Kosten und Nutzen
 - b. Nur der Anschaffungspreis
 - c. Nur die Zahl der beteiligten Mitarbeitenden
 - d. Nur die Reputation
 - e. Keine von a. bis d.
14. Was gehört zu einer Reaktionsstruktur für disruptive Ereignisse?
- a. Klar definierte Rollen, Stellvertretungen, Aktivierung, Ausführung, Koordination und Kommunikation
 - b. Nur eine allgemeine E-Mail-Adresse
 - c. Ausschließlich die IT-Abteilung
 - d. Verzicht auf dokumentierte Verfahren
 - e. Keine von a. bis d.
15. Welches Instrument gehört zur Leistungsüberprüfung eines BCMS?
- a. Übungen und Tests mit dokumentierter Auswertung
 - b. Verzicht auf Kennzahlen
 - c. Ausschließliche Prüfung nach einem echten Notfall
 - d. Nur finanzielle Jahresabschlüsse
 - e. Keine von a. bis d.
16. Welche Aussage zu AAO und BAO ist richtig?
- a. Die AAO ist dauerhaft für den Normalbetrieb; die BAO ist zeitlich begrenzt für außergewöhnliche Situationen.
 - b. Die BAO ist die normale Linienorganisation.
 - c. Die AAO ersetzt den Krisenstab.
 - d. Beide Begriffe sind identisch.
 - e. Keine von a. bis d.

17. Welche Organisation gehört typischerweise zu den BOS?
- a. Polizei oder Feuerwehr
 - b. Marketingabteilung
 - c. Lieferant eines Bauteils
 - d. Interne Revision
 - e. Keine von a. bis d.
18. Wer führt typischerweise ein 2nd-Party-Audit durch?
- a. Eine Organisation prüft einen Lieferanten oder eine andere externe Partei mit direktem Interesse.
 - b. Die interne Revision prüft sich selbst.
 - c. Eine akkreditierte Zertifizierungsstelle erteilt ein Zertifikat.
 - d. Eine Behörde führt eine Strafverfolgung durch.
 - e. Keine von a. bis d.
19. Welche Feststellung ist typischerweise eine Major-Nichtkonformität?
- a. Eine einzelne fehlende Versionsnummer
 - b. Ein einzelner fehlender Schulungsnachweis
 - c. Es gibt keine Risikoanalyse und keine Managementbewertung.
 - d. Ein Tippfehler in einer Kontaktliste
 - e. Keine von a. bis d.
20. Welche Aussage beschreibt das Zusammenspiel von BIA und ITSCM?
- a. Die BIA liefert RTO/RPO-Anforderungen; ITSCM übersetzt sie in Kritikalitätsklassen, Pläne und Tests.
 - b. ITSCM legt die Geschäftsziele ohne Fachbereiche fest.
 - c. BIA und ITSCM haben keine Schnittstelle.
 - d. ITSCM ersetzt die Risikobewertung des BCM.
 - e. Keine von a. bis d.

Prüfungsabschnitt 2: Freitextaufgaben

Aufgaben 2 bis 6 - insgesamt 40 Punkte

Antworten Sie fachlich präzise und strukturiert. Stichpunkte sind zulässig, sofern die Zusammenhänge klar erkennbar sind.

Aufgabe 2 (8 Punkte) - Grundbegriffe und Nutzen des BCM

Definieren Sie Business Continuity, Business Continuity Management System und Resilienz. Nennen Sie außerdem zwei interne und zwei externe Vorteile eines systematischen BCM.

Aufgabe 3 (8 Punkte) - Anwendungsbereich und Stakeholder

Beschreiben Sie die drei Dimensionen der Scope-Definition. Erläutern Sie, wie Stakeholder, externe Abhängigkeiten und begründete Ausschlüsse in einem Scope-Statement berücksichtigt werden.

Aufgabe 4 (8 Punkte) - BCM-Risikomanagement

Beschreiben Sie den Ablauf von Risikoidentifikation, -analyse, -bewertung und -behandlung. Erläutern Sie die Funktion einer Risikomatrix und nennen Sie die vier typischen Behandlungsoptionen.

Aufgabe 5 (8 Punkte) - Krisenmanagement und FOR-DEC

Grenzen Sie Störung, Notfall und Krise voneinander ab. Erläutern Sie die Rollen von AAO, BAO und BOS und stellen Sie die sechs Schritte der FOR-DEC-Methode dar.

Aufgabe 6 (8 Punkte) - IT-Service Continuity Management

Grenzen Sie ITSCM und BCM voneinander ab. Beschreiben Sie präventive IT-Notfallvorsorge, reaktive IT-Notfallbewältigung sowie Zweck und Ablauf der ITSCM-Kritikalitätsanalyse.

Prüfungsabschnitt 3: Case Study

Fallstudie New Generation Autos (NGA)

NGA bereitet ein externes Vor-Audit gegen ISO 22301 vor. Die BCM-Leitlinie ist durch die Geschäftsleitung freigegeben, der Scope ist dokumentiert und eine BIA liegt vor. Im Audit werden folgende Sachverhalte festgestellt:

- Für die Produktions- und Marketing-Notfallpläne wurde bislang kein einziges Übungs- oder Testprogramm durchgeführt. Die Pläne wurden daher noch nie praktisch validiert.
- Für einen Stellvertreter im Marketing fehlt ein einzelner Schulungsnachweis. Im Interview kann die Person ihre Rolle und die Eskalationswege jedoch korrekt erklären.
- Der Produktionsleiter Ralf Dickel kann die Aktivierungsschwelle und seine Aufgabe im Notfallteam nicht erläutern.

Während des Audit-Tages wird die Produktions-IT durch Ransomware verschlüsselt. Die Produktion steht vollständig. Es besteht der Verdacht, dass auch Online-Backups kompromittiert wurden. Ein geprüftes Offline-Backup ist noch nicht bestätigt. IT-4all meldet, dass die vertragliche RTO von 8 Stunden möglicherweise nicht eingehalten wird. Erste Medienanfragen gehen ein.

Aufgabe 7 (20 Punkte) - Auditfeststellungen und Korrekturmaßnahmen

Bearbeiten Sie die folgenden Teilaufgaben:

- a) Formulieren Sie aus dem fehlenden Übungsprogramm eine Major-Nichtkonformität und aus dem einzelnen fehlenden Schulungsnachweis eine Minor-Nichtkonformität. Nennen Sie jeweils Anforderung, Abweichung und objektiven Nachweis. **(10 P.)**
- b) Ordnen Sie die Feststellungen Stage I oder Stage II zu und nennen Sie passende Auditmethoden. **(4 P.)**
- c) Beschreiben Sie für die Major-Nichtkonformität den 3-Schritte-Plan aus Ursachenanalyse, Korrekturmaßnahme und Wirksamkeitsprüfung. **(6 P.)**

Aufgabe 8 (20 Punkte) - Krisenbewältigung und ITSCM

Bearbeiten Sie die folgenden Teilaufgaben:

- a) Ordnen Sie die Lage als Störung, Notfall oder Krise ein und begründen Sie Ihre Entscheidung. **(4 P.)**
- b) Wenden Sie FOR-DEC auf die Lage an. Formulieren Sie je einen nachvollziehbaren Inhalt zu Facts, Options, Risks & Benefits, Decision, Execution und Check. **(10 P.)**
- c) Nennen Sie drei vorrangige ITSCM-Maßnahmen/Ziele und drei interne oder externe Stakeholder, die koordiniert informiert werden müssen. **(6 P.)**